

JURUS - ANALYST ASSIGNMENT

“AVENGERS BANK”

Prepared by:
Azri Hafiz

TABLE OF CONTENT

PURPOSE	1
BACKGROUND	1
IDENTIFYING POTENTIAL ATTACKS	1
IDENTIFYING THE ASSET	1
IDENTIFYING THE ENTRY POINT	1
IDENTIFYING THE ACTOR	1
HELPING AVENGERS BANK WITH AWS	2
INITIATIVE 1 - EFFECTIVE DISTRIBUTION OF LOAD AND A SELF-HEALING INFRASTRUCTURE THAT RECOVERS FROM FAILURE AND ABILITY TO ACCOMMODATE INCREASES OF TRAFFIC LOAD.	2
INITIATIVE 2 - FILTERING OF MALICIOUS TRAFFIC, INCLUDING XSS AND SQL INJECTION.	3
INITIATIVE 3 - UNAUTHORISED ACCESS TO PII INFORMATION BY EXTERNAL OR INTERNAL MALICIOUS ACTORS	3
INITIATIVE 4 - SECURITY OF DATA AT REST AND IN TRANSIT ACROSS THE ENTIRE ARCHITECTURE, WHILST LIMITING THE MANAGEMENT OF CERTIFICATES OR ENCRYPTION KEYS	4
INITIATIVE 5 - SECURING AND DELEGATING APPROPRIATE ACCESS TO THE AWS ENVIRONMENT AND OPERATING SYSTEMS AS THE TEAM GROWS.	4
INITIATIVE 6 - ABILITY TO EASILY MANAGE AND REPLICATE MULTIPLE ENVIRONMENTS BASED ON THEIR BLUEPRINT ARCHITECTURE	5
INITIATIVE 7 - DEPLOYING SECURITY, COMPLIANCE GOVERNANCE ACROSS MULTIPLE AWS ACCOUNTS.	5
INITIATIVE 8 - AUTOMATIC REMEDIATION ON COMMON SECURITY THREAT PATTERNS.	5
SEEING IS BELIEVING	6
SUMMARY	6
REFERENCES	8
APPENDIX A - PROPOSED DIAGRAM	9

1. PURPOSE

The purpose of this document is to propose an industry standard security control and recommendation to Avengers Bank Cloud Digitization Program. This document also will be used to identify possible attacks based on threat modelling and highlight how AWS can assist Avengers Bank to perform the countermeasure of those attacks.

2. BACKGROUND

Avengers Bank is planning to migrate their Online Customer Portal which is currently hosted on-premises to the cloud. The portal contains functionality to allow customers to check their account, recent transactions, spending habits, and pay bills. This portal contains Application Server (developed using Java Servlets and JSP) and Oracle Database to support its functionality. The design needs to support hybrid deployment models as the portal needs to maintain its integration with the Avengers Bank's core services system located on-premise.

3. IDENTIFYING POTENTIAL ATTACKS

To identify potential attacks towards the Avengers Bank's Online Customer Portal, this document will highlight few items based on the instant threat modelling process as follows;

3.1. IDENTIFYING THE ASSET

Based on the description from the customer scenario, among the assets that can be identified are the Online Customer Portal itself which includes the application server and the Oracle Database Server, the Core Service banking platform (located on-prem), the source code of the Online Customer Portal system, and the customer data inside the Oracle Database Server and Core Service banking platform.

3.2. IDENTIFYING THE ENTRY POINT

Based on the diagram on *APPENDIX A*, there are a few entry points that can be identified, such as through the Online Customer Portal itself using the web services (http/https), the Bastion Host (RDP/SSH), the AWS Console, and the VPN tunnel from the on-premise data center and the office.

3.3. IDENTIFYING THE ACTOR

The document generally categorizes the type of actor into a few categories such as the User (Customer of Avengers Bank), Web Developer, and System Administrator. The user normally will access Online Customer Portal through a web browser. Web Developers on the other hand will have constant access to the Application Server and the Database to update the portal from the Avengers Bank Office. The System Administrator is the one that holds the key, and has administrator access to the AWS Console and its components to maintain the infrastructure from the Avengers Bank Office.

Based on the criteria and information above, this document identifies a few possible attacks that have the potential to target the Online Customer Portal. From the identified assets and entry points, there are potential attacks on the **confidentiality** and **integrity** of the asset which target the Application Server and subsequently the Oracle Database Server. Such attacks include the Layer 7 web application attack such as SQL Injection, XSS, R/LFI, directory traversal, and many more. The attack also might target the **availability** of the Online Customer Portal by producing an enormous volume of traffic/request (DDoS attack) to the application server. This will cause the application server unable to handle requests from legitimate users,

and subsequently affecting the Oracle Database as well. DDoS on the cloud environment does not only attack the **availability** of the Portal, but it also will have a huge impact on the operation cost due to the per-usage billing of the AWS resources.

From the identified Actors, there are a few potential attacks on **Authentication, Authorization, and Accounting (AAA)**. Misconfiguration on the user privilege and roles might give access to the Web Developer to execute unauthorized activity on the resources such as creating a new local user on the EC2 instances, deleting the table, copying certain sensitive data, etc. On the other hand, the sensitive data held by System Administrator such as the API key might be leaked, thus creating serious issues on the system. Last but not least, all the users are human, and humans have weaknesses. This allows the attacker to exploit human's weakness by attacking them using phishing and social engineering techniques. Information gathered from the phishing and social engineering such as email, username, and password can be used to allow the attacker to have unauthorized access to the AWS Console and the resources.

4. HELPING AVENGERS BANK WITH AWS

Based on the list of the potential attacks highlighted, AWS can help Avengers Bank to countermeasure each of the attacks through its services and align it back with the **Security Pillar of AWS Well-Architected Framework**. It consists of key concepts, design principles, and architectural best practices for designing and running workloads in the cloud, especially in AWS. The initiative that will be proposed as follows.

4.1. INITIATIVE 1 - EFFECTIVE DISTRIBUTION OF LOAD AND A SELF-HEALING INFRASTRUCTURE THAT RECOVERS FROM FAILURE AND ABILITY TO ACCOMMODATE INCREASES OF TRAFFIC LOAD.

On June 7th 2017, a 4 hours power outage at Klang and Ipoh caused a total blackout to the entire area due to the faulty cables and underground drilling work that accidentally damaged a cable powering the area [1]. This kind of unpredictable threat caused serious issues with business specifically to the **Availability** of the assets. In order to overcome the similar issue, organizations need to design the infrastructure to support redundancy, and recovery from failure caused by the threat.

AWS can help Avengers Bank in achieving this by providing redundancy on the infrastructure through its **Elastic IP Address** and **Availability Zone** [2]. All of the critical components of Online Customer Portal will be deployed in two different availability zones to survive any possibilities of infrastructure failure in one of the zones. The Elastic IP Address will be used to mask the failure of an instance in one Availability Zone by rapidly remapping the address to an instance in another Availability Zone. This will make sure that no configuration changes need to be done to resolve the Domain Name as well as any backend process that relies on the IP address for its integration.

Load Distribution is very important to the infrastructure because it will affect the response time and user experience of the Online Customer Portal. To assist Big Bang in managing this, the **Elastic Load Balancer** can be used to distribute workloads across multiple compute resources, such as virtual servers. Using a load balancer increases the availability and fault tolerance of Avengers Bank's applications.

Another important aspect of a successful online portal is **Scalability**. **AWS Auto-Scaling Group** allows the Avengers Bank's infrastructure to grow automatically to support the request and needs of resources without manual intervention from the AWS User [4]. The Auto-Scaling Group also will help Avengers Bank in managing their resources (subsequently the Cost) by provisioning sufficient resources and instances to handle a certain number of requests from their customer. By doing this, Avengers Bank only pay for the resources that they really use, at specific time periods.

4.2. INITIATIVE 2 - FILTERING OF MALICIOUS TRAFFIC, INCLUDING XSS AND SQL INJECTION.

Web Application such as Avengers Bank's Online Customer Portal will attract adversaries to launch the attack on its infrastructure and application layer. The attack on Web Applications such as DDoS, SQL Injection, XSS, and any malicious traffic [5] will cause serious issues on the CIA of the assets. AWS through **AWS CloudFront, Route 53, Web Application Firewall (WAF), and AWS Shield** services can help Avengers Bank on protecting the resources from such attacks [6]. **AWS WAF** will inspect each HTTP/HTTPS request that passes through it to look for any malicious request that could do harm to the application. If the request matches with the WAF signature, the WAF will drop the traffic before reaching the Online Customer Portal resources.

AWS Shield on the other hand will help Avengers Bank handle volumetric attacks like DDoS towards the Infrastructure. All AWS customers benefit from the automatic protections of AWS Shield Standard, at no additional charge. AWS Shield Standard defends against the most common, frequently occurring network and transport layer DDoS attacks that target the Online Customer Portal web application. These services receive comprehensive availability protection against all known infrastructure (Layer 3 and 4) attacks [7].

Avengers Bank also can utilize the **AWS Security Group** and **NACL** to control and limit the access towards certain resources, and segregate the virtual network amongst each resource [8].

4.3. INITIATIVE 3 - UNAUTHORISED ACCESS TO PII INFORMATION BY EXTERNAL OR INTERNAL MALICIOUS ACTORS

Personal Identifiable Information (PII) is a type of sensitive information that is regulated by a lot of regulatory bodies such as General Data Protection Regulation (GDPR) [9] for European countries and Personal Data Protection Act (PDPA) [10] for Malaysia. In order to detect PII information flying through the environment, Avengers Bank can utilize **Amazon Macie Classic** services, which can help Avengers Bank in identifying and protecting various data types, including PII, PHI, regulatory documents, API keys, and secret keys [11]. The Amazon Macie Classic does not only help Avengers Bank on handling its PII, but it also helps to verify compliance with automated logs that allow for instant auditing.

4.4. INITIATIVE 4 - SECURITY OF DATA AT REST AND IN TRANSIT ACROSS THE ENTIRE ARCHITECTURE, WHILST LIMITING THE MANAGEMENT OF CERTIFICATES OR ENCRYPTION KEYS

As a well-known and largest bank in the country, **Confidentiality** of its data-at-rest and data-in-transit is something that Avengers Bank takes seriously. The security portion of this data can be handled by using the public key infrastructure and certificate management. However, managing the PKI and certificate is a complex process and requires a lot of resources especially on the Process, People, and Technology. Understanding the hassle, AWS can help Avengers Bank to manage this using **AWS Certificate Manager (ACM)** or **AWS Certificate Manager Private Certificate Authority (ACM PCA)**. The ACM service handles the complexity of creating and managing public SSL/TLS certificates for Avengers Bank AWS based websites and applications. These public certificates verify the identity and authenticity of Online Customer Portal and the ownership of Avengers Bank's public keys. The ACM PCA on the other hand helps Avengers Bank to create and manage private certificates, which can be used to authenticate the identity of internal organization entities. Avengers Bank also can use ACM to create wildcard SSL certificates that can protect an unlimited number of subdomains for future expansion [12].

In addition to that, to secure the Data-in-Transit between AWS Infrastructure with Avengers Bank's Data Center, AWS provides **Direct Connect** connectivity that serves as a private connection between the virtual private cloud. On top of that, a **VPN Connection** can also be created to encrypt the traffic being sent through the DirectConnect over the SSL [13].

To help Avengers Bank protect the Data-at-Rest, the **AWS Elastic File System (EFS)** can encrypt all the data and metadata on behalf of Avengers Bank before it is written to disk and is decrypted before it is read by clients. The AWS EFS also can be integrated with AWS IAM to apply the encryption to a specific classification or is associated with a particular application, workload, or environment [14].

4.5. INITIATIVE 5 - SECURING AND DELEGATING APPROPRIATE ACCESS TO THE AWS ENVIRONMENT AND OPERATING SYSTEMS AS THE TEAM GROWS.

As the team at Avengers Bank grows, the process to maintain the roles and privileges to the appropriate user becomes more complex and troublesome. To make it worse, misconfiguration or inappropriate privileges assignment may result in users obtaining full access to all resources in an account. AWS can help Avengers Bank on managing the issue of appropriate access by utilizing its **Identity and Access Management (IAM)**. AWS IAM manages the user/group access towards the entire AWS infrastructure to control the access and privilege of users towards certain information [15]. **The Least Privileges Principle** can be applied to the IAM services to grant only the permissions required to perform a task by the user [16]. Avengers Bank also can apply the **Separation of Duty** policies to separate the business and operational needs within the permission. In order to combat phishing, password guessing, and social engineering attacks towards Avengers Bank employees and its cloud environment, AWS offers **Multi Factor Authentication (MFA)** within its IAM as another layer to protect the user.

4.6. INITIATIVE 6 - ABILITY TO EASILY MANAGE AND REPLICATE MULTIPLE ENVIRONMENTS BASED ON THEIR BLUEPRINT ARCHITECTURE

There will be times when Avengers Bank need to replicate some portion of their environment due to disaster recovery activity, or creating a development-production environment for their developer to test and deploy the web application. For example, let's say that Avengers Bank wants to copy its Web Application and database setup from 1 region into different regions due to expansion or business needs. AWS can help Avengers Bank to achieve this by using its **AWS CloudFormation**, which provides a common language to describe and pre-configure all the infrastructure resources in Avengers Bank's environment [17].

AWS CloudFormation allows Avengers Bank to use simple text files across all regions and accounts to model and pre-configure the relevant resources that the Online Customer Portal needs in an automated and secure way.

In addition to that, AWS can assist Avengers Bank's developers translating their Java Servlets and JSP code into suitable instances by using **AWS Beanstalk** [18]. It allows the developers to focus on the code development instead of Operating System and the platform so that the development of the code becomes smooth and easy. Avengers Bank's developers can utilise AWS Beanstalk at no extra charges and will need to bear the resources fee only.

4.7. INITIATIVE 7 - DEPLOYING SECURITY, COMPLIANCE GOVERNANCE ACROSS MULTIPLE AWS ACCOUNTS.

Compliance and Governance are very important to make sure that organizations provide oversight roles in managing and mitigating business risk. It is also important to make sure that organizations follow a standard process and requirement imposed by the compliance body. Oftentimes, Compliance and Government can cause the production to be slower due to the roadblock and challenges imposed on the developer when operating the environment. With AWS, it does not have to be that way. **AWS Config** will enable the organization to standardize processes and keep track of any changes within the AWS environment. It will help Avengers Bank to evaluate the configuration against policies that have been set-up across all the AWS accounts. If there are any non-compliance resources within the AWS environment, an alert will be sent to the Avengers Bank compliance officer through **AWS CloudWatch** so that the fix can be done to remediate the issue [19].

4.8. INITIATIVE 8 - AUTOMATIC REMEDIATION ON COMMON SECURITY THREAT PATTERNS.

Logs will represent Events, Events will become Alert, and Alert indicates Incidents. Among the challenges faced by a lot of organizations is that there is an enormous volume of logs produced by the monitored services thus making it harder to identify suspicious events from the logs. These logs need to be handled appropriately so that it gives essence to the organization to respond to the alert. By using the AWS infrastructure, Avengers Bank can access and collect logs from a lot of sources such as **AWS CloudWatch**, **AWS Cloudtrail**, **AWS VPC Flows**, **AWS WAF**, and many more. Avengers Bank can utilize the **AWS Guard Duty** and **AWS Security Hub** to consolidate the logs into a centralized console, and serve as a

threat detection system that continuously monitors for malicious activity and unauthorized behavior to protect Avengers Bank's AWS accounts, workloads, and many more [20].

With AWS GuardDuty and AWS Security Hub, Avengers Bank now has an intelligent and cost-effective option for continuous threat detection in AWS. By integrating with Amazon CloudWatch Events, GuardDuty alerts are actionable, easy to aggregate across multiple accounts, and straightforward to push into existing event management and workflow systems.

5. SEEING IS BELIEVING

It is understandable when organizations feel insecure with things that they can't see. Customers might have a lot of doubts in regards to Data Sovereignty, Data Ownership, Data Remanence, etc. where Cloud Service Providers need to convince customers on how they dealt with this issue. That is why cloud security at AWS is the highest priority. As an AWS customer, Avengers Bank will benefit from a data center and network architecture built to meet the requirements of the most security-sensitive organizations. The **Shared Responsibility Model** that we propose allows both parties (AWS and Avengers Bank) to take responsibility for the security on the cloud. While AWS manages security of the cloud, Avengers Bank will be responsible for security in the cloud. This means that Avengers Bank will retain full control of the security that needs to be implemented to protect the Online Customer Portal no differently than it would in an on-site data center [21]. The cloud infrastructure that has been provided by AWS to its customers aligned with the **best security practices** and a variety of **IT security standards**. Among the security standard that which AWS complies as follows [22];

- SOC 1/ISAE 3402, SOC 2, SOC 3
- FISMA, DIACAP, and FedRAMP
- PCI DSS Level 1
- ISO 9001, ISO 27001, ISO 27017, ISO 27018

In terms of regulatory and compliance, AWS understands that Avengers Bank need to cover a variety of contractual and operational areas, including due diligence, risk management, business continuity, monitoring and oversight. AWS is committed to offer Avengers Bank a strong compliance framework and advanced tools and security measures that Avengers Bank can use to evaluate, meet, and demonstrate compliance with applicable legal and regulatory requirements. Avengers Bank can use the **RMiT Workbook** from **AWS Artifact** as the guideline to AWS' security and compliance reports and select online agreements [23].

6. SUMMARY

In this document, the proposed solution highlights all the necessary requirements, concerns, risk, and how AWS helps Avengers Bank to handle the issue. The documents also take into consideration the industry's best security practice, potential threats based on threat modelling, and the **security pillar** of **AWS Well-Architected framework**.

In AWS, we work backwards by understanding the problem faced by our customers, how current solutions are failing, and how we can innovate the technology to solve this problem. The services and solutions that are offered in this document cover a variety of problems that have been faced by our customers and that can be applied to Avengers Bank as well. This is the

journey that we will share with Avengers Bank to grow together towards the digitization program.

REFERENCES

- [1] <https://www.malaymail.com/news/malaysia/2017/06/07/tnb-temporary-power-outage-in-klang-and-ipoh-due-to-faulty-cables/1394479>
- [2] <https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/using-regions-availability-zones.html#concepts-availability-zones>
- [3] <https://docs.aws.amazon.com/elasticloadbalancing/latest/userguide/what-is-load-balancing.html>
- [4] <https://docs.aws.amazon.com/autoscaling/ec2/userguide/AutoScalingGroup.html>
- [5] <https://docs.aws.amazon.com/whitepapers/latest/aws-best-practices-ddos-resiliency/application-layer-attacks.html>
- [6] <https://docs.aws.amazon.com/AmazonCloudFront/latest/DeveloperGuide/distribution-web-aws-waf.html>
- [7] <https://docs.aws.amazon.com/waf/latest/developerguide/ddos-overview.html>
- [8] https://docs.aws.amazon.com/vpc/latest/userguide/VPC_SecurityGroups.html
- [9] <https://gdpr-info.eu/>
- [10] <https://www.pdp.gov.my/jpdpv2/laws-of-malaysia-pdpa/personal-data-protection-act-2010/?lang=en>
- [11] <https://docs.aws.amazon.com/macie/latest/userguide/what-is-macie.html>
- [12] <https://docs.aws.amazon.com/crypto/latest/userguide/awspki-service-toplevel.html>
- [13] <https://docs.aws.amazon.com/whitepapers/latest/aws-vpc-connectivity-options/aws-direct-connect.html>
- [14] <https://docs.aws.amazon.com/whitepapers/latest/efs-encrypted-file-systems/enforcing-encryption.html>
- [15] <https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/iam-roles-for-amazon-ec2.html>
- [16] <https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html#grant-least-privilege>
- [17] <https://aws.amazon.com/blogs/aws/cloudformation-create-your-aws-stack-from-a-recipe/>
- [18] <https://docs.aws.amazon.com/elasticbeanstalk/latest/dg/java-getstarted.html>
- [19] https://pages.awscloud.com/Implementing-Governance-and-Compliance-in-a-Multi-Account-Multi-Region-Scenario_1021-MGT_OD.html
- [20] <https://aws.amazon.com/guardduty/>
- [21] <https://aws.amazon.com/compliance/shared-responsibility-model/>
- [22] <https://aws.amazon.com/compliance/>
- [23] <https://aws.amazon.com/artifact/>

APPENDIX A - PROPOSED DIAGRAM

